

HTB ACADEMY

Security Monitoring & SIEM Fundamentals

HTB Academy · Module 211 · SOC Blue Team Track · Study Notes

Condensed study notes for all 11 sections of the module — theory, architecture, and a front-loaded command index for fast lookup while working in Kibana.

Module	Security Monitoring & SIEM Fundamentals (#211)
Completion	100% — all 11 sections
Analyst	Chayan Panchal · @tron874
Format	Quick-reference index first, then topic-by-topic notes

Command & Query Index — Read This First

Every KQL query, event ID, and build step from the module, in one place, so you never have to hunt through the notes mid-investigation.



KQL — every query used in the module

```
event.code:4625
event.code:4625 AND winlog.event_data.SubStatus:0xC0000072
event.code:4625 AND winlog.event_data.SubStatus:0xC0000072
  AND @timestamp >= "2023-03-03T00:00:00.000Z"
  AND @timestamp <= "2023-03-06T23:59:59.999Z"
event.code:4625 AND user.name: admin*
NOT user.name: *$ AND winlog.channel.keyword: Security
user.name: svc-*
"svc-sql1"                # free-text search
event.code: 4624 AND winlog.logon.type: RemoteInteractive
(event.code: 4732 OR 4733) AND group.name: administrators
```



Windows Security Event IDs + SubStatus codes

4624 Successful logon	4720 Account created
4625 Failed logon	4728 Added to global group
4648 Explicit-cred logon	4732 Added to local group
4672 Special privileges	4733 Removed from local group
	4740 Account locked out
	4756 Added to universal group
SubStatus 0xC0000072 disabled account	0xC0000064 no such user
SubStatus 0xC000006A wrong password	0xC0000234 locked out



Universal Kibana Lens build workflow

1. Dashboard -> Create visualization
2. Time range -> calendar icon -> "last 15 years"
3. Index pattern -> windows* (or linux*, etc.)
4. Add filter -> event.code is <ID>
5. Add extra filters (SubStatus, logon type, ...)
6. Chart type -> switch to Table
7. Rows -> field.keyword -> top 1000 values
8. Add more Rows for extra columns
9. Metrics -> Count
10. KQL search bar for extra narrowing if needed
11. Save visualization -> name it
12. Save dashboard

1 SIEM Fundamentals — What It Is, How It Works

SIEM in plain language: big log collector + smart pattern matcher + alert sender. Without one, thousands of logs sit in separate systems with nobody connecting the dots. With one, everything is correlated in real time.



Era	Name	What changed
~2000	SIM	Log storage + retention + reporting. No real-time detection.
~2003	SEM	Real-time correlation from IDS/AV/FW. No log storage.
~2005	SIEM	Combined SIM + SEM — storage AND real-time detection.
SOC 1.0	Network-centric	Perimeter focus, siloed tools, uncorrelated alerts.
SOC 2.0	Intel-driven	Threat intel, anomaly detection, layer-7, proactive hunting.
Cognitive	AI-augmented	ML + behavioural analytics + automated response.

NOTE SOC 2.0 follows a **proactive** defence approach — it hunts for threats before they fully materialise instead of just reacting to alerts. This was a module question.

2 The Elastic Stack — Your SIEM Platform

Component	Role	Key concept to remember
Elasticsearch	Stores/indexes/searches all logs as JSON	An index = a database table for logs (windows* = all matching indices)
Logstash	Collect -> transform -> send	Input / filter / output plugins; adds processing power to ingestion
Kibana	Your primary analyst interface	Discover (search), Dashboards, Lens (drag-drop viz builder)
Beats	Lightweight shippers on endpoints	Filebeat (logs), Winlogbeat (Windows), Metricbeat, Packetbeat

TIP Remember the flow: **Beats** (collect on endpoint) → **Logstash** (process) → **Elasticsearch** (store) → **Kibana** (visualise/query). Small environments often skip Logstash and ship Beats straight to Elasticsearch.

3 SOC Roles, Tiers & How a SOC Works

Tier	Job	Escalate to them when...
Tier 1	Monitor alerts, initial triage. Focus on speed.	You escalate anything you cannot explain
Tier 2	Deep analysis of escalated incidents, root cause, tune rules	Lateral movement suspected, persistence found
Tier 3	Most complex incidents, proactive hunting, advanced DFIR	Nation-state level threats, zero-days, major breaches
Detection Eng.	Write/maintain SIEM rules, IDS sigs, EDR policies	Detection gaps found, new TTPs published
IR Lead	Contain, eradicate, recover from active incidents	Confirmed compromise requiring containment

4 MITRE ATT&CK — Mapping Detections to Threats

Level	Definition	Example
Tactic	The adversary's goal — the “why”	TA0002 Execution
Technique	How the goal is achieved — the “what”	T1127 Trusted Dev Utilities Proxy Exec
Sub-technique	Specific variation	T1127.001 MSBuild specifically
TTP	All three combined	Full picture of attacker behaviour



Module example — MSBuild abuse

```
Scenario : Excel.exe / Word.exe launches MSBuild.exe
Why odd  : Office apps have no reason to run MSBuild
Type     : LoLBin (Living off the Land Binary)
Tactic   : TA0005 Defense Evasion + TA0002 Execution
Technique : T1127 -> T1127.001 (MSBuild)
Severity  : HIGH

2nd scenario: MSBuild makes an outbound connection
Severity    : MEDIUM -- check IP reputation before escalating
```

NOTE LoLBins (Living-off-the-Land Binaries) are legitimate Windows tools attackers abuse to run malicious code while evading detection — MSBuild, rundll32, mshta, certutil. Any unexpected parent process for these is a red flag.

5 KQL — Writing Queries in Kibana

Syntax	Meaning	Live example
field:value	Match exact value	event.code:4625
"term"	Free text, all fields	"svc-sql1"
AND / OR / NOT	Logical operators	event.code:4732 OR event.code:4733
field: val*	Starts with	user.name: svc-*
field: *val*	Contains	user.name: *admin*
field: *val	Ends with	user.name: *\$ (computer accounts end in \$)
field:>=<= val	Range	@timestamp >= "2023-03-03T00:00:00.000Z"

IMPORTANT Use `field.keyword` (e.g. `user.name.keyword`) in Kibana Lens Rows/Columns for aggregations. Use the plain field in KQL filter queries. Mixing these up is the most common mistake when building visualizations.

6 Windows Security Event IDs — What to Monitor

Event ID	What happened	Why SOC analysts care
4624	Successful logon	Monitor service-account RDP, admin logons outside PAW
4625	Failed logon	Brute force, disabled-account auth, admin targeting
4648	Logon using explicit credentials	Pass-the-hash or credential reuse indicator
4672	Special privileges assigned	Admin privilege use — log every occurrence
4720	User account created	Detect backdoor accounts being created
4728 / 4756	Added to global / universal group	Domain-level privilege escalation
4732	Added to local security group	Local Administrators group changes
4733	Removed from local security group	Account tampering, covering tracks
4740	Account locked out	Result of a brute-force attack

TIP SubStatus 0xC0000072 (disabled account) was the key filter in Visualization 2. A disabled account being used for a login attempt means someone still has those credentials — always worth escalating.

7 Alert Triage & Skills Assessment

The ideal triage process:

1. Initial review — what triggered it, what time, which system, which user
2. Classification — assign severity: Critical / High / Medium / Low
3. Correlation — cross-reference with other alerts, is this part of a pattern?
4. Enrichment — gather packet captures, threat intel, process trees
5. Risk assessment — what is the potential impact if this is real?
6. Contextual analysis — known false positive? controls already in place?
7. Consult IT Ops if the activity could be legitimate maintenance
8. Decision — Nothing suspicious / Consult IT Ops / Escalate to Tier 2/3
9. Document — timeline, findings, actions taken, who was notified
10. Escalate (if needed) with a full summary of findings

Skills assessment — all 7 answers, reasoning included:

sql-svc1 failed logins (all users)

Service accounts run automated processes — they should not fail logins unless something changed.

CONSULT IT OPS**“anni” disabled-account auth attempt**

Someone had those credentials and tried to use them — suspicious regardless of success.

ESCALATE**Admin login failures (admin users only)**

All came from PAWs or Domain Controllers — exactly where admin activity is expected.

NOTHING SUSPICIOUS**svc-sql1 RDP to PKI server**

Service accounts in this org run local services only — they never RDP. Major red flag.

ESCALATE**Unknown SID added to Administrators**

Could be a new IT admin or an attacker — needs IT Ops to confirm.

CONSULT IT OPS**Admin logon from non-PAW machine**

Against policy, but could be IT oversight — needs clarification.

CONSULT IT OPS**Root SSH login detected**

Environment policy blocks root SSH — this cannot be legitimate.

ESCALATE

8 Bonus Reference — Beyond This Module

Not covered directly in Module 211, but this is the kind of reference a working Tier 1 analyst keeps close at hand. Added here because it's genuinely useful, not because HTB asked for it.

More Windows Security event IDs worth knowing

Event ID	What it means	Why it matters
4688	A new process was created	Core telemetry for process-tree / LOLBin detection
4697	A service was installed on the system	Common persistence mechanism
4698	A scheduled task was created	Another common persistence mechanism
4776	Domain controller validated credentials	NTLM auth — brute force and relay detection
5140	A network share object was accessed	Lateral movement via SMB shares
1102	The audit log was cleared	Extremely high-signal — attackers covering tracks

The full MITRE ATT&CK tactic list (Enterprise matrix)

 14 Enterprise ATT&CK tactics — the full "why" list	
TA0043 Reconnaissance	TA0007 Discovery
TA0042 Resource Development	TA0008 Lateral Movement
TA0001 Initial Access	TA0009 Collection
TA0002 Execution	TA0011 Command and Control
TA0003 Persistence	TA0010 Exfiltration
TA0004 Privilege Escalation	TA0040 Impact
TA0005 Defense Evasion	TA0006 Credential Access

Common false-positive patterns worth knowing before you escalate

Pattern	Usually benign when...
Failed logon spike	Coincides with a password-expiry cycle or a mapped drive using stale creds
New admin group member	Change ticket / IT maintenance window lines up with the timestamp
Off-hours logon	User is in a different timezone, or a scheduled task runs under their account
Unusual parent process	Software deployment tool (SCCM, Intune) legitimately spawns odd children

PRINCIPLE None of these patterns are automatically safe to dismiss — they're reasons to look closer, not reasons to skip triage. The habit that actually protects an environment is confirming the benign explanation, not assuming it.